Global Threat Actors Deploy New iOS Exploit

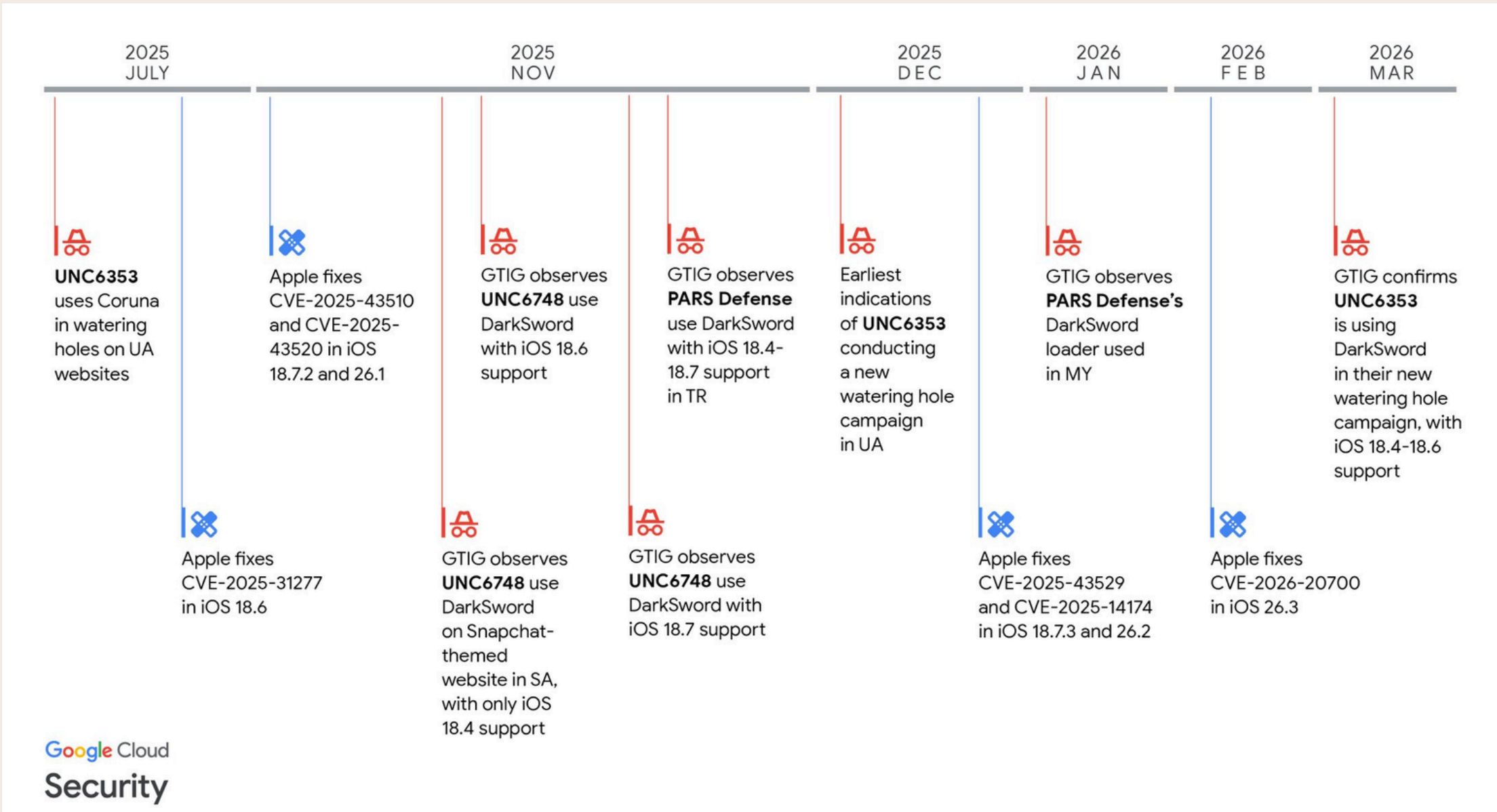


A Threat Intelligence by Google Threat Intelligence Group

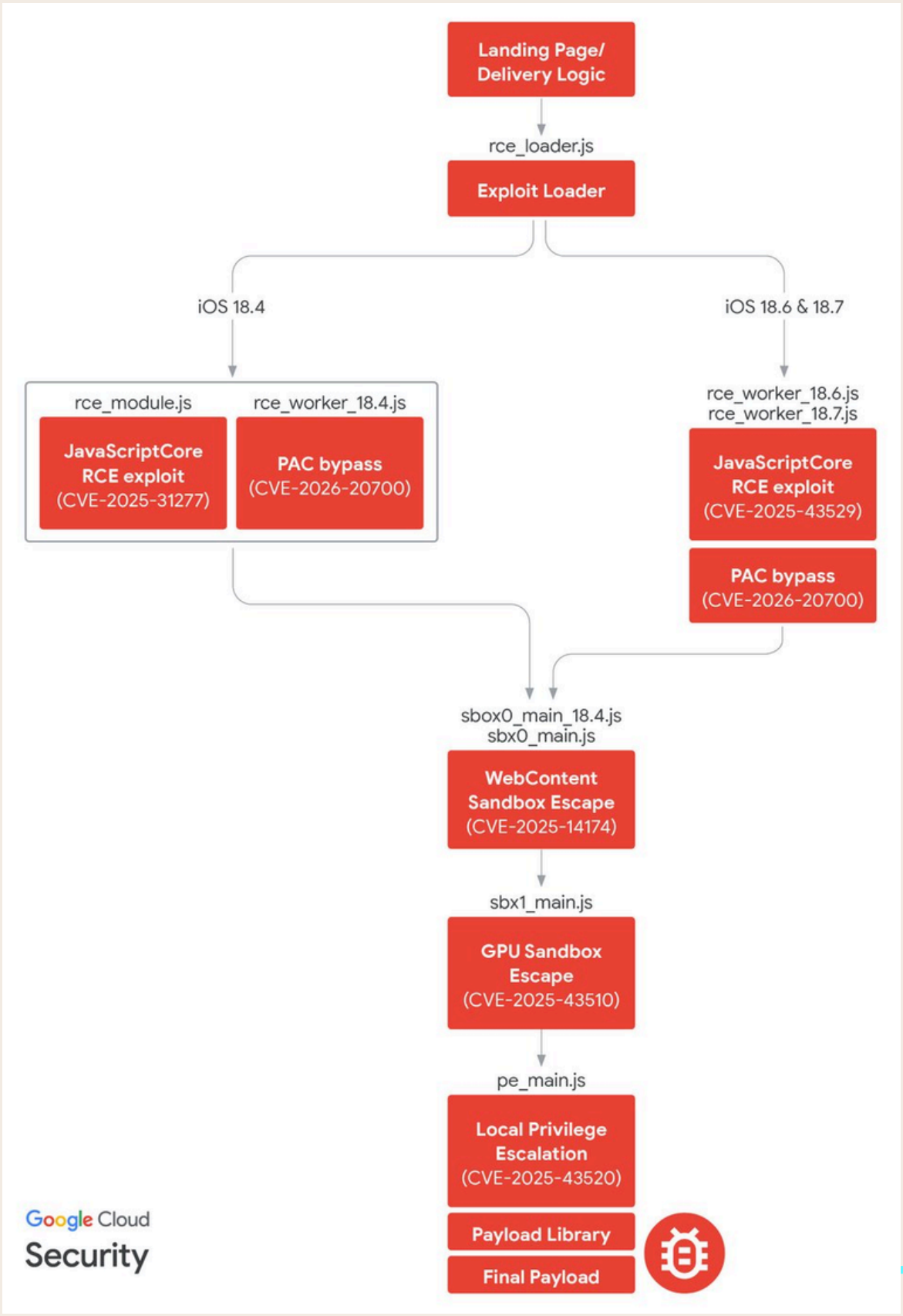
Memori CTI

Executive Summary

Security researchers from Google, Lookout, and iVerify recently uncovered a highly dangerous exploit kit called **"DarkSword"** that is actively targeting devices running iOS 18.4 through 18.7. Used by commercial spyware vendors and state-backed hackers, this silent attack chains multiple zero-day vulnerabilities to bypass Apple's security with zero user interaction. In a rapid "hit-and-run" operation, it steals sensitive data, such as private chats, passwords, and crypto wallets.



What is DarkSword and How Does It Work?



DarkSword is an advanced infostealer capable of seizing full control of a device with zero-click or minimal user interaction. Deployed against targets in Turkey, Saudi Arabia, Malaysia, and Ukraine, this tool has been actively fielded primarily by a suspected espionage group tracked as UNC6353.

Key technical details of the attack

- **6 Different Vulnerabilities and Zero-Days:** The attack chain combines a total of 6 vulnerabilities, including 3 flaws (CVE-2026-20700, CVE-2025-43529, CVE-2025-14174) that were exploited as "zero-days" before Apple released patches.
- **Complex Sandbox Escape:** The malware bypasses WebContent protections by exploiting Safari and WebGPU vulnerabilities. It elevates privileges on the device by infiltrating the GPU process first, and then moving deeper into the system (mediaplaybackd). Following this stage, payloads like GHOSTBLADE, GHOSTKNIFE, or GHOSTSABER are deployed.
- **"Hit-and-Run" Tactic:** The most devastating aspect of the attack is its speed. Within minutes of infiltrating the device, DarkSword exfiltrates sensitive data such as cryptocurrency wallets, WhatsApp/Telegram chats, iCloud files, passwords, and location history. It then completely covers its tracks and vanishes from the device before traditional security products (EDR/MTR) can detect the anomaly.

Preventative Measures and Mitigation Strategies

DarkSword proves once again that mobile devices are the most valuable yet least monitored targets in both corporate and personal attack surfaces. To protect against such espionage and data theft operations, the following steps are critical:

- **Urgent iOS Update:** Apple has detected and patched the aforementioned security flaws (sandbox escape, remote code execution) in the latest operating system releases. Immediately upgrade your devices to the most current iOS version.
- **Lockdown Mode:** If an immediate system update is not feasible, or if you are a high-risk individual (corporate executive, journalist, activist, etc.), activate Lockdown Mode on your iOS device. This mode severely restricts the background processes and web technologies exploited by chains like DarkSword, effectively shrinking the attack surface.
- **Behavioral Network Monitoring:** Corporate security teams (SOC), even if they cannot monitor the mobile device directly, should employ unified risk engines (like UEBA) that detect anomalies in the device's access to the corporate network (VPN, email servers, internal apps). Even if the malware hides its tracks on the device, it will leave a footprint on the network while exfiltrating data or accessing company resources.